
Breach Response Plan

Organisation: JSL Sports Technology Ltd **Incident Commander (default):** John Leitch, Director **Last updated:** April 2026 **Next drill:** October 2026 (every 6 months)

■■ Legal timeline under UK GDPR

Time	Action
T+0	Breach detected or reported
T+1 hour	Incident Commander notified; response begun
T+24 hours	Affected academies/parents notified (if risk to rights)
T+72 hours	ICO notification submitted (ico.org.uk/for-organisations/report-a-breach)
T+7 days	Post-incident report written
T+14 days	Lessons learned review + policy updates

Missing the 72-hour window = automatic fine liability under UK GDPR Article 33.

■ What counts as a "personal data breach"

Any event that results in:

- **Unauthorised disclosure** of data (e.g. wrong parent sees another child's info)
- **Unauthorised access** (e.g. hacker gets into Supabase)
- **Accidental loss** (e.g. data deleted with no backup)
- **Destruction** (e.g. corrupted DB, lost backup)
- **Alteration** (e.g. data tampering)

Even internal incidents count — e.g. a staff member copying a parent list to their personal email.

■ Response steps (in order)

Step 1 — Contain (T+0 to T+1 hour)

Goal: Stop the bleeding.

- [] Identify the source (what system, what data, how many people affected)
- [] Revoke compromised credentials (rotate API keys, force password reset for affected users)

- ☐ Disable compromised accounts
- ☐ Take affected systems offline if active exploitation is ongoing
- ☐ **Preserve evidence** — take screenshots, export audit logs, save any relevant data

Step 2 — Assess (T+1 to T+24 hours)

Goal: Understand impact.

- ☐ What data was affected? (Personal? Special category? Children's?)
- ☐ How many data subjects?
- ☐ Which academies?
- ☐ Is the data recoverable?
- ☐ Is there a risk to the rights and freedoms of data subjects?
- **High risk** → notify affected parents within 24 hours
- **Low risk** → log internally, no public notification needed

Decision tree for risk assessment:

Was special category data (medical, biometric) affected? ■■■■ YES → HIGH RISK → notify affected parents ■■■■ NO → Continue ↓

Was children's data affected? ■■■■ YES → HIGH RISK → notify ■■■■ NO → Continue ↓

Is there a risk of identity theft, fraud, or financial loss? ■■■■ YES → HIGH RISK → notify ■■■■ NO → Likely LOW RISK, log only ```

Step 3 — Notify ICO (T+24 to T+72 hours)

Goal: Legal compliance.

- ☐ Submit report at ico.org.uk/report-a-breach
- ☐ Include:
 - Nature of breach
 - Categories and approximate number of data subjects
 - Likely consequences
 - Measures taken / proposed
 - Contact details of DPO or director
- ☐ Keep the ICO reference number — retain for records

If unsure whether to report: ICO guidance says *"if in doubt, report it."* They prefer false positives over silent breaches.

Step 4 — Notify affected data subjects (if high risk)

Send an email within 24-72 hours of breach detection. Template:

``` Subject: Important: security incident affecting [Academy Name]'s records

Dear [Parent name],

---

We are writing to inform you of a security incident at Player Portal, the platform your academy [Academy Name] uses to manage training.

What happened: [brief factual description] When: [date] What data was affected: [specific categories, e.g. "your child's name and age group"] What was NOT affected: [reassurance, e.g. "no payment card data, no medical records"]

What we have done:

- [Contained the incident]
- [Forced password resets]
- [Engaged [insurer/forensics]]

What you should do:

- [Change your password at [theplayerportal.net/auth/signin](https://theplayerportal.net/auth/signin)]
- [Monitor your account for suspicious activity]
- [Contact us with any concerns: [safeguarding@theplayerportal.net](mailto:safeguarding@theplayerportal.net)]

We have reported this incident to the Information Commissioner's Office under our legal obligations.

We take your family's data seriously and are deeply sorry this has occurred. If you have any questions, please reply to this email or call [number].

[John Leitch, Director, JSL Sports Technology Ltd] ```

## **Step 5 — Notify academies**

Every academy whose data was affected receives a direct call + email from the Director within 24 hours.

## **Step 6 — Insurer & solicitor**

- [ ] Notify cyber insurance carrier — they may provide forensics, PR support, legal counsel
- [ ] Notify solicitor — they handle any regulatory correspondence
- [ ] Keep contemporaneous notes — date, time, every decision made

## **Step 7 — Investigate & remediate**

- [ ] Root cause analysis — how did this happen?
- [ ] Technical fix — patch the vulnerability
- [ ] Policy fix — what process broke down?
- [ ] Staff training — what do we teach?

## **Step 8 — Post-incident report (T+7 days)**

Written report including:

- Timeline of events
- What data was affected
- Who was notified (ICO, parents, academies, insurer)
- Root cause

- Remediation
- Prevention measures

File at `/legal/incidents-register/[YYYY-MM-DD]-incident-report.md`

## Step 9 — Lessons learned (T+14 days)

Director-led review:

- What went well?
- What went badly?
- Policy/process/tech changes?
- Update DPIA if data processing has changed
- Update this Breach Response Plan

## ■ Contact list (populate before incident)

| Role                                        | Name        | Email                            | Phone   |
|---------------------------------------------|-------------|----------------------------------|---------|
| Incident Commander                          | John Leitch | [email]                          | [phone] |
| Solicitor                                   | [TO ADD]    | [email]                          | [phone] |
| Cyber Insurer claim line                    | [TO ADD]    | —                                | [phone] |
| Supabase support                            | —           | support@supabase.com             | —       |
| Stripe support                              | —           | support@stripe.com               | —       |
| Designated Safeguarding Lead (if different) | John Leitch | safeguarding@theplayerportal.net | —       |

## ■ Common breach scenarios and responses

### Scenario A: Someone's password is compromised

- Revoke session, force password reset
- Audit their account activity for the last 30 days
- If they had admin access, treat as moderate-severity
- Usually NOT reportable to ICO unless data was actually exfiltrated

### Scenario B: Bug causes wrong academy to see another academy's data

- Immediately disable the feature
- Assess how long the bug was live
- Count affected users per academy

- 
- Likely REPORTABLE to ICO
  - Notify both academies

### **Scenario C: Sub-processor breach (e.g. Supabase)**

- They have their own legal obligations
- We still notify our academies
- Review our DPA with them and any indemnities

### **Scenario D: Stolen laptop with DB access**

- Immediately rotate all keys that laptop had
- Force password reset on all admin accounts
- Audit recent access patterns
- Report to ICO (device loss is reportable even without confirmed access)

### **Scenario E: Phishing attack on a parent → they lose access to their child's records**

- This is a scam, not a platform breach — but still help them
  - Force password reset
  - Educate via blog post / email to all academies
  - Not reportable if no platform-side breach occurred
- 

## **■ Mini drill — do this every 6 months**

1. Pretend Scenario B happens
2. Work through the checklist in real time (no skipping steps)
3. Note how long each step took
4. Identify any gaps (e.g. "I couldn't find the insurer's number")
5. Update this document

---

*This plan should be familiar to anyone with admin access to Player Portal infrastructure. Print and keep a copy accessible — don't rely on digital-only during an outage.*